

Hafta 12 – Güvenlik Sertifikasyonları ve Sızma Testi Planlaması

Tarih	04.12.2026
Öğrenme çıktıları	ÖÇ.5, 6, 7
Süre	3 saat



Bu haftanın çalışan demosu

`code/week-12/01-birim-test` — Birim test kosucusu: guvenlik fonksiyonlarini test kartlariyla dogrular (S16 sonuclari). · `code/week-12/02-saldiri-potansiyeli` — Saldırı potansiyeli hesaplayıcı: beş faktör → dirençlik düzeyi (düşük = ciddi bulgu).

Çalıştırma: `sh demo.sh` (Linux/WSL) ya da CMake ile derleyip `bin/` altından. Tümüyle sentetik ve güvenlidir; öğrenci bilgisayarına zarar vermez.



Demoyu kendiniz çalıştırın — adım adım (kopyala-yapıştır)

İlk derleme `code/README.md` 'de anlatılır. `code` klasöründen:

```
# Windows (PowerShell)
.\build.ps1
cd week-12\01-birim-test
.\bin\windows\birim_test.exe
cd ../02-saldiri-potansiyeli
.\bin\windows\saldiri_potansiyeli.exe
```

```
# WSL / Linux
./build.sh
cd week-12/01-birim-test && ./bin/linux/birim_test
cd ../02-saldiri-potansiyeli && ./bin/linux/saldiri_potansiyeli
```

Beklenen çıktı: Birim test koşucusu iki güvenlik fonksiyonunu **test kartlarıyla** sınar; her test için amaç/gözlenen/karar basar ve **çıkış kodu = başarısız test sayısıdır** (hepsi geçerse 0 — S16'nın "plan değil **sonuç**" mantığı). İkinci demo beş faktörden (zaman · uzmanlık · bilgi · fırsat · ekipman) **toplam puanı ve dereceyi** hesaplar.

**Bu haftanın sonunda şunları yapabileceksiniz**

1. Bir ürünün **bağımsız bir laboratuvar**da güvenlik değerlendirmesinden geçişini uçtan uca, adım adım anlatmak.
2. ETSI, EMV, PCI DSS ve ISO/IEC 27001'in **ne tür güvenlik testleri** istediğini ayırt etmek.
3. Kod incelemesi, statik ve dinamik analiz, fuzzing ve sızma testini bir **zafiyet değerlendirmesi** içinde doğru sırada kullanmak.
4. Bir **sızma testi planı** yazmak: kapsam, kurallar (angajman kuralları), yöntem (OWASP WSTG/MASTG, PTES, NIST SP 800-115) ve raporlama.
5. Bir bulguyu **saldırı potansiyeli** ve CVSS ile derecelendirmek; bulgu-öneri-aksiyon döngüsünü ve **güvenlik etki analizi / delta değerlendirmeyi** açıklamak.

**Ders akışı (öğretim üyesi için zaman planı)**

Zaman	Bölüm	Ne yapılıyor
0:00–0:20	1	Neden bağımsız değerlendirme? Standartlar ve sertifikasyon manzarası
0:20–0:50	2	Değerlendirme süreci: hedef tanımindan delta değerlendirmeye 13 adım
0:50–1:00	Ara	
1:00–1:30	3–4	Zafiyet değerlendirmesinin araçları; standartların istediği testler
1:30–1:50	5	Saldırı potansiyeli ve bulgu derecelendirme
1:50–2:00	Ara	
2:00–2:35	6	Sızma testi planı: kapsam, kurallar, yöntem, test şablonu – takım etkinliği
2:35–2:50	7–8	Raporlama; eleştirel okuma alıştırmaları
2:50–3:00	9+	Proje adımı (S16 test planı), kendini sınama

**Etik ve hukuki çerçeve**

Sızma testi, **yazılı izin** ve kapsamı açıkça tanımlanmış bir sözleşme olmadan yapılamaz. İzinsiz test, amacı ne olursa olsun suçtur. Bu haftanın bütün etkinlikleri kendi dönem projeleriniz ve ders demoları üzerinde, kağıt üstünde **planlama** olarak yapılır; başka bir takımın projesini test etmek ancak o takımın ve öğretim üyesinin onayıyla, ders ortamında olur.

0. Temel kavramlar (sıfırdan)

Bu bölüm **hiçbir ön bilgi varsaymaz**. Haftanın geri kalanında kullanacağımız terimleri sıfırdan tanımlıyoruz. Bir terimi bilmiyorsanız önce burayı okuyun; sonraki bölümler bunların üzerine kurulur.

Neden bu bölüm?

Bu hafta "değerlendirme", "sertifikasyon", "sızma testi" gibi terimler geçecek.

Önce hepsini **tek tek** tanımlayalım ki konu havada kalmasın.

Güvenlik değerlendirmesi nedir?

- **Güvenlik değerlendirme**: bir ürünün güvenlik iddialarının **bağımsız** biri tarafından **sınanması**.
- "Ben güvenliyim" demek yetmez; **kanıt** ve **test** gerekir.

Sertifikasyon nedir?

- **Sertifikasyon**: bir ürünün/kurumun belirli bir **standartta** uyduğunun, yetkili bir tarafça **belgelenmesi**.
- Değerlendirme başarılıysa bir **sertifika** verilir.

Laboratuvar (değerlendirici) kim?

- **Değerlendirme laboratuvarı**: ürünü sınavan bağımsız, akredite kuruluş.
- Ürünü geliştiren **değildir** (tarafsızlık için).
- Bütün kaynak koda ve belgeye erişir.

Standart nedir?

- **Standart**: neyin nasıl yapılacağını belirleyen ortak kurallar bütünü.
- Örnek: ISO/IEC 27001, Ortak Kriterler, FIPS 140-3, PCI, OWASP MASVS.
- Her biri farklı şeyi ölçer (birazdan).

Zafiyet (vulnerability) nedir?

- **Zafiyet**: bir sistemde kötüye kullanılabilecek **zayıf nokta** (ör. sınır denetimsiz tampon).
- Zafiyet + kötüye kullanım = güvenlik olayı.

Bulgu (finding) nedir?

- **Bulgu**: değerlendirmede tespit edilen bir sorun ya da iyileştirme noktası.
- Her bulgu için: kanıt, ciddiyet, **öneri**.

Beyaz kutu vs kara kutu test

- **Beyaz kutu test**: test eden **kaynak koda + belgeye** sahip.

- **Kara kutu test:** test eden yalnız dışarıdan (kullanıcı gibi) erişir.
- Değerlendirici genelde **beyaz kutu** çalışır (her şeyi görür).

SAST nedir?

- **SAST (Static Application Security Testing):** kaynağı **çalıştırmadan** analiz eden araç.
- Tehlikeli kalıpları, olası bellek hatalarını bulur.
- Hızlı ve geniş; ama **yanlış pozitif** üretir.

(4. haftada "statik analiz" olarak gördük.)

DAST nedir?

- **DAST (Dynamic Application Security Testing):** programı **çalıştırırken** sınar.
- Bellek erişim hataları, tanımsız davranışları yakalar (ör. sanitizeler'lar).

(4. haftada ASan/UBSan.)

Fuzzing nedir?

- **Fuzzing:** programa **beklenmeyen/rastgele girdiler** verip çökme/bozulma aramak.
- İnsanın aklına gelmeyen girdileri bulur.

(4. haftada libFuzzer/AFL kavramı.)

Sızma testi (pentest) nedir?

- **Sızma testi (penetration test):** bir saldırganın bakışıyla, **izinli** ve **planlı** olarak sistemi aşmayı denemek.
- Yukarıdaki yöntemleri **birleştirir**; en son ve en pahalı adımdır.

TOE nedir?

- **TOE (Target of Evaluation):** değerlendirilen **tam olarak ne?**
- Ortak Kriterler terimidir.
- Benzersiz tanımlanır: sürüm + ikili + kaynak + özet değeri.

CVSS nedir?

- **CVSS (Common Vulnerability Scoring System):** bir zafiyetin **etkisini** standart bir puanla (0–10) ifade eder.
- Yüksek puan = daha ciddi etki.
- Önceliklendirmede kullanılır.

Saldırı potansiyeli nedir?

- **Saldırı potansiyeli:** bir saldırıyı gerçekleştirmenin **ne kadar zor** olduğu.
- Süre, uzmanlık, ekipman gibi faktörlerle puanlanır.

- Düşük potansiyel (kolay saldırı) = ciddi bulgu.

Saldırı potansiyeli — beş faktör



Düşük potansiyel = az zaman/beceri/araç → çok saldırgan yapabilir → yüksek risk.

Saldırı potansiyeli = saldırının ZORLUĞU · CVSS = açığın ETKİSİ (ayrı eksenler).

Etki analizi ve delta değerlendirme

- **Güvenlik etki analizi:** bir değişikliğin güvenlik etkisini **belgeleyen** rapor.
- **Delta değerlendirme:** yalnız **değişen kısmın** yeniden değerlendirilmesi.

Bunları 5. bölümde ayrıntılı göreceğiz.

Şimdi hazırız

Bildiğimiz terimler:

değerlendirme · sertifikasyon · laboratuvar · standart · zafiyet · bulgu · beyaz/kara kutu · SAST · DAST · fuzzing · sızma testi · TOE · CVSS · saldırı potansiyeli · etki analizi/delta

Şimdi: **neden bağımsız değerlendirme?**

1. Neden bağımsız değerlendirme?

Bir yazılımı yazan ekip, onun en iyi test edicisi değildir: tasarım varsayımlarını paylaşır, "bu nasılsa olmaz" dediği yolları hiç denemez. Bu yüzden ödeme, kimlik, sağlık ve kamu gibi alanlarda ürünler, **bağımsız bir laboratuvarın** değerlendirmesinden geçer. Değerlendirmenin sonunda bir sertifika (ya da onay) verilir; sertifika "bu ürün kırılmaz" demez, "bu ürün şu standardın şu gereksinimlerini, şu saldırgan modeline karşı, şu tarihte karşılıyordu" der.

Neden bağımsız değerlendirme?

üretici kendi ürününü onaylayamaz

Geliştiricinin sözü

tarafıdır (çıkar çatışması)
kendi hatasına kördür
elinde kanıt yoktur

'bence güvenli'

Bağımsız değerlendirme

tarafsız laboratuvar
tanımlı yöntem
KANIT üretir

'şu testte şu sonuç'

Değerlendirici iki şey varsayar: saldırgan sistemi tam bilir ve yetenekli/kaynaklıdır.



Kısa tarihçe: güvenlik değerlendirmesi ve sertifikasyon

- **1985** — ABD **TCSEC** ("Orange Book"): ilk resmi güvenlik değerlendirme ölçütleri.
- **1991–1993** — Avrupa **ITSEC** ve Kanada **CTCPEC**.
- **1999** — bunlar **Ortak Kriterler (ISO/IEC 15408)** altında birleşir; **EAL** güvence ölçeği buradan gelir (13. hafta).
- **2001** — **OWASP** kurulur (uygulama güvenliği testi kültürü); sonra **PTES** ve **NIST SP 800-115** sızma testi metodolojilerini standartlaştırır.
- **2005** → **2023** — **CVSS** zafiyet ciddiyet puanı (v2 → v3.1 → v4.0).
- **2010'lar** — mobil için **OWASP MASVS/MASTG**, tüketici IoT için **ETSI EN 303 645**.

Ortak fikir tek cümlede: **üretici kendi ürününü onaylayamaz** — bağımsız, kanıta dayalı değerlendirme gerekir.

Bu dersin projesini baştan beri "bir sertifikasyondan geçecekmiş gibi" tasarladık. Bu hafta o sürecin kendisini, bir değerlendiricinin gözünden, adım adım işliyoruz.

Standartlar ve sertifikasyon manzarası

Standart / şema	Alan	Ne değerlendirilir?	Bu dersteki yeri
Ortak Kriterler (ISO/IEC 15408) + CEM (ISO/IEC 18045)	Genel BT ürünleri	Güvenlik hedefi (ST), koruma profili (PP), EAL düzeyleri; zafiyet analizi ve saldırı potansiyeli	13. hafta
FIPS 140-3	Kriptografik modüller	Modülün krypto algoritmaları, anahtar yönetimi, fiziksel güvenlik, öz testler	13. hafta
EMVCo belgeleri	Ödeme kartları, terminaller, mobil ödeme	Çip ve yazılım tabanlı ödeme çözümlerinin güvenlik değerlendirmesi	3, 6, 11, 13. haftalar
PCI standartları (DSS, PIN, MPoC, SSF)	Kart verisi işleyen kurum ve yazılımlar	Kart verisinin korunması; yazılımın güvenli geliştirilmesi; test ve tarama gereksinimleri	Bu hafta
ISO/IEC 27001	Kurumun bilgi güvenliği yönetim sistemi	Süreçler, risk yönetimi, kontroller (Ek A); ürün değil kurum sertifikalanır	Bu hafta
ETSI (EN 303 645, TS 103 732 vb.)	Tüketici IoT, telekom, mobil	Cihaz güvenliği temel gereksinimleri, test belirtileri	13. hafta
OWASP ASVS / MASVS	Web ve mobil uygulamalar	Uygulama güvenliği doğrulama düzeyleri (sertifika değil, test çerçevesi)	5, 6. haftalar

Ürün mü, süreç mi?

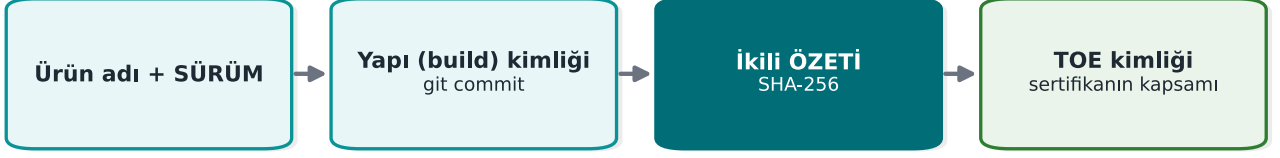
ISO/IEC 27001 bir **kurumu** (onun bilgi güvenliği yönetim sistemini) sertifikalar; Ortak Kriterler, FIPS 140-3 ve EMVCo değerlendirmeleri ise bir **ürünü**. PCI DSS, kart verisi işleyen bir ortamın uyumunu denetler. Bir proje kılavuzunda bu farkı karıştırmamak gerekir: "ürünümüz ISO 27001 sertifikalı" cümlesi yanlıştır; "ürünümüz ISO 27001 sertifikalı bir kurumda geliştirilmektedir" doğrudur.

2. Değerlendirme süreci: 13 adım

Aşağıdaki akış, bir yazılım bileşeninin (ör. bir mobil ödeme kütüphanesi) üçüncü taraf bir laboratuvar da değerlendirilmesinin genelleştirilmiş halidir. Ürün, kurum ve şema adları çıkarılmıştır; adımlar birçok şemada benzerdir.

TOE neden benzersiz tanımlanır?

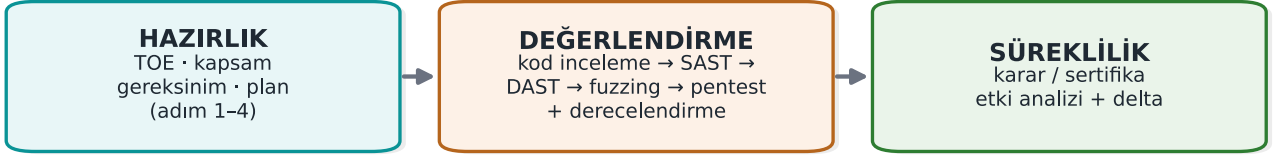
sertifika bir ANLIK FOTOĞRAFTIR



Tanım belirsizse başka bir sürüm 'sertifikalı' görünür — sertifika geçersizleşir.

Değerlendirme süreci: üç aşama, 13 adım

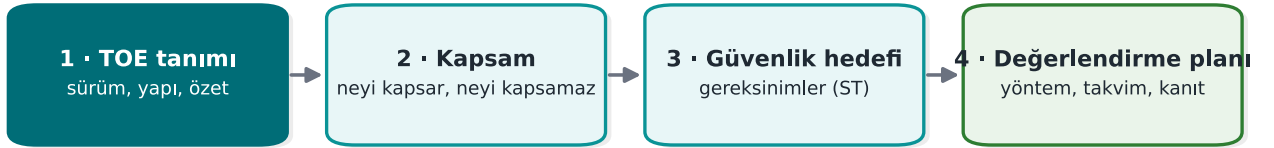
üretici kendi ürününü onaylayamaz



Sertifika bir anlık fotoğraftır: her değişiklikte etki analizi ve delta değerlendirme gerekir.

Hazırlık aşaması: adım 1-4

yanlış tanımlanmış TOE, tüm değerlendirmeyi geçersiz kılar



TOE benzersiz tanımlanmazsa 'hangi sürüm sertifikalı?' sorusu yanıtız kalır.

Adım	Ne yapılır?	Çıktı	Projenizde
1. Değerlendirme hedefi	Değerlendirilecek şey benzersiz tanımlanır: sürüm numarası yetmez; ikili dosya + kaynak kod + özet değeri ya da sürüm etiketi. Kapsam dışı bileşenler yazılır. Varsayım: platform güvenilirmez	TOE tanımı	S0, S1 (1. hafta sürüm kimliği)
2. Belgelerin teslimi	Kaynak kod, API belgesi, güvenlik kılavuzu , hata ayıklama ve sürüm derlemeleri güvenli bir kanalla teslim edilir	Teslim listesi	Deponuz + kılavuz
3. Gereksinim şablonu	Standardın numaralı gereksinimleri; her biri için gereksinim metni, test kapsamı , geliştiricinin uyum gerekçesi ve belge referansı ; durum: karşılandı / devredildi / karşılanmadı	Doldurulmuş şablon	S17 uyum matrisi (13. hafta)
4. Atölye	Hangi önlemin hangi gereksinimi karşıladığı, eksiklerin nasıl kapatılacağı planlanır	Belge güncelleme planı	—
5. Kaynak kod incelemesi	Bütün kaynak, laboratuvar beyaz kutu bağlamında incelenir: tehlikeli kalıplar, yanlış kript, sızıntı noktaları	Kod inceleme bulguları	4. hafta CERT, statik analiz
6. Zafiyet analizi	Varlıklar ve anahtar hiyerarşisi çıkarılır; her varlık için "nerede, hangi halde açığa çıkıyor?" sorulur	Bulgu listesi + sızma testi planı	S4, S5, S16
7. Sızma testi	Plandaki her test, sekiz başlıklı şablonla yürütülür ve saldırı potansiyeliyle derecelendirilir	Test sonuç tabloları	S16
8. İşlevsel uygunluk	Ürünün standart işlevleri (ör. ödeme akışları) şemanın test paketiyle sınanır	Yürütme raporu	Birim testleri
9. Bulgular ve düzeltmeler	Her bulgu için laboratuvar öneri, geliştirici aksiyon üretir; bazı bulgular "güvenlik sorunu değil, iyi uygulama önerisi" olarak kapanır	Bulgu–aksiyon tablosu	7. hafta bulgu listesi
10. Güvenlik etki analizi	Düzeltilmeler yeni sürüm doğurunca: değişiklik dizini (yeni özellik / iyileştirme / hata düzeltme), etkilenen dosyalar, güvenlik etkisi	Etki analizi belgesi	S13, 1. hafta değişiklik yönetimi
11. Delta değerlendirme	Yalnız değişen kısım yeniden değerlendirilir; laboratuvar işaretlenmiş belgeler, etki analizi, dosya listesi ve yeni TOE kimliğini ister	Delta raporu	—
12. Ödünleşim ve kalan risk	Her korumanın maliyeti ölçülür, kararlar gerekçelendirilir, kalan risk açıkça yazılır	Ödünleşim kaydı	1. hafta
13. Değişiklik yönetimi	Temel çizgi → talep → sınıflandırma → onay → geliştirme ve test → yayın → doğrulama	Süreç kayıtları	S13



Sahada nasıl uygulanır?

Bu dersin her haftasında gördüğümüz "Sahada nasıl uygulanır?" notlarının kaynağı olan kılavuz, tam olarak 2. adımda teslim edilen **güvenlik kılavuzudur**: birincil okuru değerlendirme laboratuvarıdır. Kılavuzun her bölümü bir gereksinim bloğuyla açılır ("gereksinim — durum"), ardından ürünün o gereksinimi nasıl karşıladığı anlatılır. Dönem projenizde yazdığınız kılavuz, bu belgenin küçültülmüş halidir.

Değerlendiricinin temel tutumu

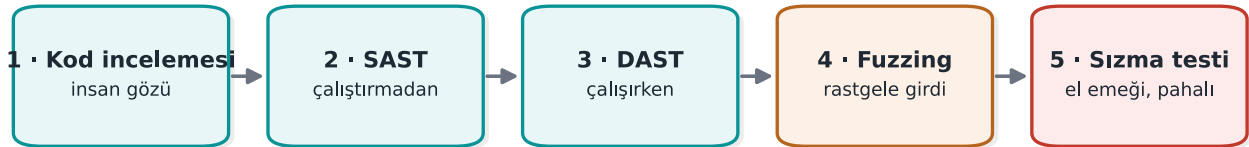
Değerlendirici iki varsayımla çalışır: (1) bütün kaynak koda ve belgelere erişimi vardır (**beyaz kutu** bağlam) ve (2) ürünün çalıştığı platform güvenilmezdir. Bu yüzden bir korumanın **var olması** yetmez; **ne kadar kolay aşıldığı** ölçülür. Tek bir korumayı değil, korumaların **birlikte** aşılmasının ne kadar sürdüğünü raporlar; iyi tasarlanmış bir üründe saldırgan birkaç korumayı **zincirlemek** zorunda kalır.

3. Zafiyet değerlendirmesinin yöntemleri

Değerlendirme sürecinin 5. ve 6. adımları (kod incelemesi ve zafiyet analizi), bir dizi yöntemi **doğru sırada** kullanmayı gerektirir. Bunları savunmacı gözüyle, "kendi ürünümü teslim etmeden önce nasıl sınıyorum?" sorusuyla ele alıyoruz. Sıralama önemlidir: ucuz ve geniş kapsamlı yöntemlerle başlanır, pahalı ve derin yöntemlere doğru gidilir.

Zafiyet değerlendirme yöntemleri: ucuzdan pahalıya

erken adımlar kolay bulguları eler; pahalı adım yalnız kalanlara harcanır



Geliştirici önce kendi test ederse değerlendirmeye 'temiz' gider — maliyet düşer.

Sıra	Yöntem	Ne bulur?	Bu dersteki yeri
1	Kaynak kod incelemesi (el ile)	Tasarım ve mantık hataları, yanlış kriptο kullanımı, sızıntı noktaları	4. hafta CERT/CWE
2	Statik analiz (SAST)	Kaynağı çalıştırmadan: bellek hataları, tehlikeli çağrılar, kalıplar	4. hafta (statik analiz)
3	Dinamik analiz (DAST) + sanitizer'lar	Çalışırken: bellek erişim hataları, UB, sızıntılar	4. hafta (ASan/UBSan)
4	Fuzzing	Beklenmeyen girdilerle çökme/bozulma yolları	4. hafta (libFuzzer/AFL kavramı)
5	Sızma testi	Yukarıdakilerin birleştirilmesiyle, saldırgan bakışıyla aşılabilirlik	Bu hafta bölüm 6



Neden bu sıra?

Statik analiz ucuzdur ve geniş tarar ama **yanlış pozitif** üretir; el ile inceleme pahalıdır ama bağlamı görür; fuzzing çalıştırma gerektirir ama insanın aklına gelmeyen girdileri bulur; sızma testi en pahalısıdır ve en son gelir. Önce ucuz yöntemlerle "kolay" bulguları temizlemek, sızma testinin zamanını gerçek, birleşik sorunlara ayırır. Bu, 4. haftadaki "güvenli derleme hattı"nın (CI'da SAST + sanitizer + fuzz) değerlendirmedeki karşılığıdır.

Kod incelemesi: değerlendiricinin baktığı yerler

Kod incelemesi, otomatik araçların kaçırdığı **mantık** hatalarını bulur. Değerlendiricinin öncelikli baktığı yerler (hepsi önceki haftalardan):

- **Kriptο kullanımı:** doğru algoritma/kip/dolgu mu? Anahtar nereden geliyor, nereye yazılıyor, ne zaman siliniyor? (3, 10, 11. haftalar)
- **Girdi doğrulama ve bellek:** sınır denetimi, tamsayı taşması, biçim dizisi, UAF (4. hafta CERT).
- **Hata ve sır sızıntısı:** günlükte hassas veri, hata iletilerinde iç durum (4, 6. haftalar).
- **Denetim atlama yolları:** bir güvenlik denetiminin tek bir dalla ya da tek bir dönüş değeriyle atlanabilmesi (9. hafta opak boolean, rastgele çıkış).

Statik ve dinamik analiz, fuzzing

Bu üç yöntemi 4. haftada güvenli derleme hattının parçası olarak gördük. Değerlendirmede aynı araçlar, bu kez **bağımsız** bir tarafça çalıştırılır. Önemli olan, geliştiricinin bu araçları **kendisinin** çalıştırmış ve sonuçlarını (S16) sunmuş olmasıdır: değerlendirici, "bu ürünü daha önce kimse sınamamış" ile "geliştirici şu araçları çalıştırmış, şu bulguları kapatmış" arasında büyük fark görür.

4. Standartların istediği testler

Farklı standartlar farklı test türlerini vurgular. Projenizin hangi gereksinim ailesine yakın olduğunu bilmek, hangi testleri önceliklendireceğinizi belirler.

Standartlar manzarası: hangisi neyi sertifikalar?

'sertifikalı' demek, NEYİN sertifikalandığını bilmeden anlamsızdır

ISO/IEC 27001	KURUMU — bilgi güvenliği yönetim sistemi
Ortak Kriterler (15408)	ÜRÜNÜ — TOE, belirli güvence düzeyinde
FIPS 140-3	KRİPTOGRAFİK MODÜLÜ
ETSI EN 303 645	tüketici IoT cihazı
OWASP MASVS / ASVS	uygulama — geliştirici dostu öz-değerlendirme

Kurum sertifikası ürün güvenliğini, ürün sertifikası kurum olgunluğunu göstermez.

Standart / çerçeve	Ağırlıklı beklediği test	Kısa not
ISO/IEC 27001	Süreç ve yönetim denetimi	Ürünü değil, kurumu sertifikalar; test yerine kontrol kanıtı
Ortak Kriterler (ISO/IEC 15408)	Kaynak inceleme + zafiyet analizi + sızma testi; saldırı potansiyeli derecelendirme	Derinlik EAL ile artar (13. hafta)
FIPS 140-3	Kriptografik modül testleri (algoritma doğrulama, kendini test)	Yalnız modülü kapsar (13. hafta)
ETSI EN 303 645	Temel IoT güvenlik gereksinimlerinin doğrulanması	Hafif, geniş kapsamlı
EMVCo / PCI	İşlevsel uygunluk + laboratuvar sızma testi + saldırı potansiyeli	Ödeme alanı; sıkı
OWASP MASVS + MASTG	Mobil uygulama güvenlik testi (statik + dinamik)	Projeniz için en uygulanabilir rehber

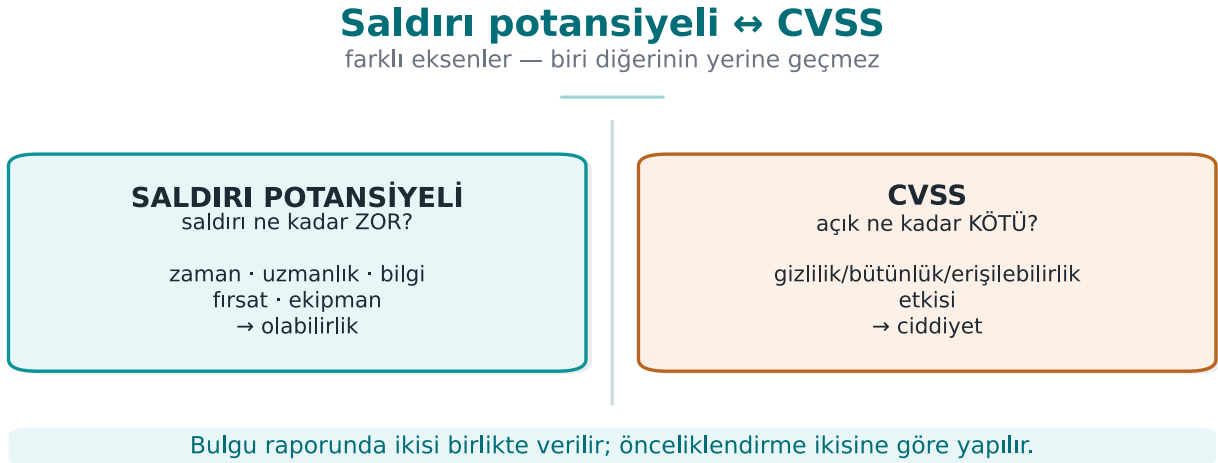


Test yöntemi rehberleri

Sızma testinin **nasıl** yürütüleceği için olgunlaşmış açık rehberler vardır: web için **OWASP WSTG**, mobil için **OWASP MASTG**, genel süreç için **PTES** ve **NIST SP 800-115**. Bunlar bir "saldırı tarifi" değil, kapsamı ve yöntemi standartlaştıran **test metodolojileridir**; bir bulgunun tekrarlanabilir ve karşılaştırılabilir olmasını sağlarlar.

5. Saldırı potansiyeli ve bulgu derecelendirme

Bir korumanın "var olması" yetmediğini, "ne kadar kolay aşıldığının" ölçülmesi gerektiğini söylemiştik. Ortak Kriterler ve ödeme şemaları bu ölçüyü **saldırı potansiyeli** (attack potential) puanlamasıyla yapar. Bir bulgunun ciddiyeti, "kırmak için ne gerekti?" sorusuna verilen yanıtla belirlenir. Bu, 9. haftadaki "gizlemenin ölçülmesi" (güç, dayanıklılık) çerçevesinin değerlendirmedeki resmî halidir.



Saldırı potansiyeli faktörleri

Bir saldırıyı gerçekleştirmek için gereken çabayı beş-altı faktörle puanlarız; her faktörün puanları toplanır ve toplam bir dirençlik düzeyine (ör. "temel / orta / yüksek / çok yüksek") eşlenir.

Faktör	Soru	Düşük puan	Yüksek puan
Geçen süre (elapsed time)	Saldırı ne kadar sürdü?	Bir gün	Aylar
Uzmanlık (expertise)	Ne düzeyde beceri gerekti?	Sıradan kullanıcı	Konu uzmanı
Hedef bilgisi (knowledge of TOE)	Ürün hakkında ne bilmek gerekti?	Kamuya açık	İç/gizli belgeler
Fırsat penceresi (window of opportunity)	Ne kadar erişim/deneme gerekti?	Sınırsız/uzaktan	Kısıtlı fiziksel erişim
Ekipman (equipment)	Hangi araçlar gerekti?	Standart, ücretsiz	Özel, pahalı

Yorum: Toplam puan **yüksekse**, saldırı zor demektir; koruma iyidir. Puan **düşükse** (ör. sıradan kullanıcı, bir saatte, ücretsiz araçla), bu ciddi bir bulgudur. Buradaki mantık 9. haftadaki dört ölçütü aynıdır: bir savunmanın gücü, onu aşmanın maliyetiyle ölçülür.



Örnek (sentetik)

"Sürüm derlemesinde bir lisans denetimi, ücretsiz bir tersine derleyiciyle, orta düzey bir kullanıcının bir saatte bulup tek bayt yamasıyla atlayabildiği bir dala bağlıydı." → süre: düşük, uzmanlık: orta, bilgi: kamuya açık, ekipman: ücretsiz → **düşük saldırı potansiyeli** → **ciddi bulgu**. Öneri: opak boolean + rastgele çıkış (9. hafta) ve sunucu tarafı denetim.

Puan tablosu (derste kullanacağımız sadeleştirilmiş ölçek)

Yukarıdaki tablo "düşük/yüksek" diyor; puanlama yapabilmek için **sayılar** gerekir. Derste (ve demoda) şu sadeleştirilmiş Ortak Kriterler/JIL ölçeğini kullanıyoruz:

Faktör	Seviye 0	Seviye 1	Seviye 2	Seviye 3
Geçen süre	< 1 gün → 0	< 1 hafta → 4	< 1 ay → 10	aylar → 19
Uzmanlık	sıradan → 0	yetkin → 3	uzman → 6	çoklu uzman → 8
Hedef bilgisi	kamuya açık → 0	kısıtlı → 3	hassas → 7	kritik → 11
Fırsat	sınırsız/uzak → 0	kısıtlı → 4	çok kısıtlı → 10	—
Ekipman	standart/ücretsiz → 0	özel → 4	özel-uyarlanmış → 7	—

Toplam puanın karşılığı:

Toplam	Düzey
0–9	TEMEL — düşük direnç → ciddi bulgu
10–13	ORTA
14–19	YÜKSEK
20–24	ÇOK YÜKSEK
25+	ÖTESİ (yalnız çok yetenekli saldırgan)

Uçtan uca örnek: bir bulguyu baştan sona puanlayalım

Senaryo. "Sürüm derlemesindeki lisans denetimi, ücretsiz bir tersine derleyiciyle, **yetkin** (uzman değil) bir kullanıcının **bir saatte** bulup **tek bayt yamasıyla** atlayabildiği bir dala bağlı."

Beş faktörü tek tek okuyup puanlıyoruz:

#	Faktör	Senaryodaki karşılığı	Seviye	Puan
1	Geçen süre	bir saat	< 1 gün	0
2	Uzmanlık	yetkin kullanıcı	yetkin	3
3	Hedef bilgisi	mağazadan inen ikili, belge gerekmedi	kamuya açık	0
4	Fırsat	kendi cihazında sınırsız deneme	sınırsız/uzak	0
5	Ekipman	ücretsiz tersine derleyici	standart/ücretsiz	0

$$\text{Toplam} = 0 + 3 + 0 + 0 + 0 = 3 \quad \rightarrow \quad 3 \leq 9 \quad \rightarrow \quad \text{TEMEL}$$

Sonuç: TEMEL düzey = düşük direnç = ciddi bulgu. Rapora "önce bu kapatılmalı" diye yazılır.

Şimdi koruma ekleyelim ve yeniden puanlayalım. 9. haftadan opak boolean + rastgele çıkış, üstüne sunucu tarafı denetim koyduk. Aynı saldırı artık: bir haftada (4), **uzman** gerektiriyor (6), iç davranışı öğrenmek **kısıtlı bilgi** istiyor (3), sunucu denetimi yüzünden deneme **kısıtlı** (4), ekipman hâlâ ücretsiz (0):

$$\text{Toplam} = 4 + 6 + 3 + 4 + 0 = 17 \quad \rightarrow \quad 14 \leq 17 \leq 19 \quad \rightarrow \quad \text{YÜKSEK}$$

Yani koruma, bulguyu **TEMEL (3)** düzeyinden **YÜKSEK (17)** düzeyine taşıdı. "Koruma ekledim" demek yerine **ölçüyle** konuşmuş olduk; S16'ya yazılacak cümle budur.



Aynı sayıları demoda üretin

code/week-12/02-saldiri-potansiyeli demosu bu ölçeği uygular. Faktör seviyelerini argüman olarak verin (sıra: süre uzmanlık bilgi fırsat ekipman):

```
./bin/linux/saldiri_potansiyeli 0 1 0 0 0 # korumasız hâl -> puan 3 (TEMEL)
./bin/linux/saldiri_potansiyeli 1 2 1 1 0 # korumalı hâl -> puan 17 (YÜKSEK)
```

Windows'ta: .\bin\windows\saldiri_potansiyeli.exe 0 1 0 0 0. Argümansız çalıştırırsanız gömülü üç örnek bulguyu (lisans yaması · WBC anahtar çıkarma · güvenli öge kırma) puanlar.

CVSS ile derecelendirme

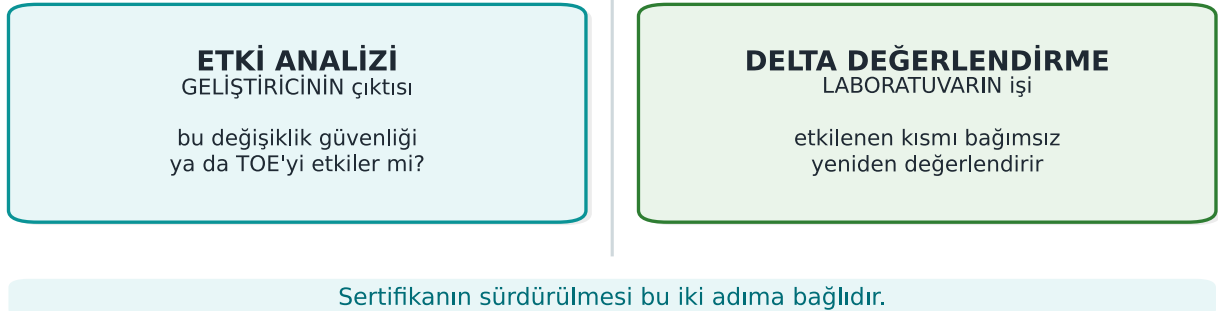
Saldırı potansiyeli "kırmak ne kadar zor?" derken, **CVSS** (Common Vulnerability Scoring System) "bu zafiyetin etkisi ne kadar büyük?" sorusuna standart bir puan verir. İki ölçü birbirini tamamlar: biri **olabilirliği** (saldırının zorluğu), öteki **etkiyi** (gizlilik/bütünlük/erişilebilirlik kaybı) tartar. Bir bulgu raporunda çoğunlukla ikisi birden verilir; önceliklendirme buna göre yapılır.

6. Bulgu → öneri → aksiyon ve etki analizi

Değerlendirme bir "geçti/kaldı" damgası değil, bir **iyileştirme döngüsüdür**. Her bulgu için:

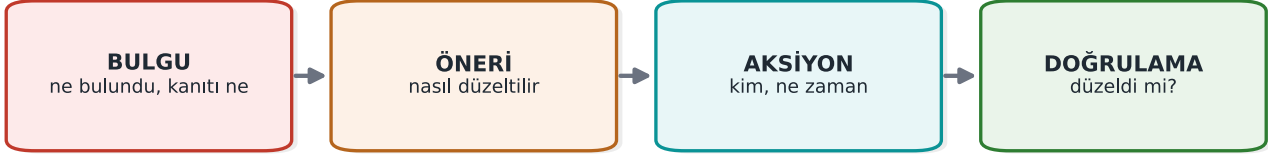
Etki analizi ↔ delta değerlendirme

her değişiklikte tüm ürün baştan değerlendirilmez



Bulgu → öneri → aksiyon döngüsü

her bulgu bir sahip ve bir tarih alır



Bir bulgu, gerçekten sömürülemez olduğu KANITLANIRSA 'etkilenmez' diye kapanır (VEX).

1. **Bulgu:** laboratuvar ne buldu (kanıtla, tekrarlanabilir biçimde).
2. **Öneri:** laboratuvarın önerdiği düzeltme yönü.
3. **Aksiyon:** geliştiricinin ne yaptığı (ya da neden yapmadığı — gerekçeli kabul de bir aksiyondur).
4. **Kapanış:** bazı bulgular "güvenlik açığı değil, iyi uygulama önerisi" olarak da kapanabilir.

Bu döngü, vize sonrası projenizde beklediğimiz **bulgu–aksiyon listesinin** (7. hafta) kaynağıdır.

Güvenlik etki analizi ve delta değerlendirme

Düzeltilmeler yeni bir sürüm doğurduğunda, her şeyi baştan değerlendirmek pahalıdır. Bu yüzden iki belge devreye girer (süreçteki 10. ve 11. adımlar):

- **Güvenlik etki analizi (security impact analysis):** Yeni sürümdeki değişiklikleri sınıflandırır (yeni özellik / iyileştirme / hata düzeltmesi), etkilenen dosyaları listeler ve her değişikliğin **güvenlik etkisini** yazar.
- **Delta değerlendirme:** Laboratuvar, bu belgeye dayanarak **yalnız değişen kısmı** yeniden değerlendirir; işaretli belgeleri, değişiklik dizinini, dosya listesini ve **yeni TOE kimliğini** ister.



Karıştırılan iki kavram

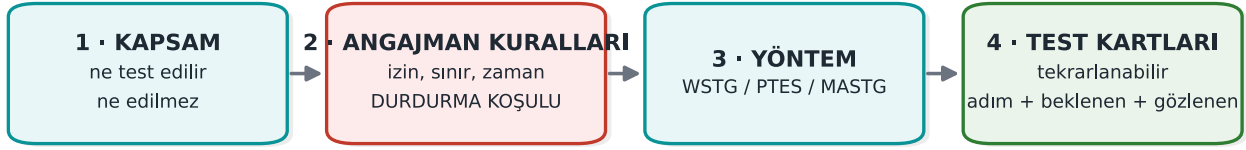
Etki analizi değişikliğin güvenlik etkisini *belgeler*; **delta değerlendirme** bu belgeye dayanıp *yalnız değişeni yeniden değerlendirir*. Biri geliştiricinin çıktısı, öteki laboratuvarın işidir. Sürüm kimliği ve özet değerleri tutarlı olmazsa delta değerlendirme yapılamaz (değerlendirilen ürün belirsizleşir).

7. Sızma testi planı

Sızma testi, yukarıdaki yöntemleri saldırgan bakışıyla birleştiren, **planlı** ve **izinli** bir etkinliktir. "Planlı" ve "izinli" sözcükleri isteğe bağlı değildir: kapsamı ve kuralları yazılı olmayan bir test, meşru bir güvenlik çalışması değildir. Bir plan en az şu dört başlığı içerir.

Sızma testi planının dört başlığı

plan olmadan yapılan test ne tekrarlanabilir ne de savunulabilir



Durdurma koşulu, gerçek zarar/veri kaybı riskini sınırlar — etik ve güvenli yürütme.

1. Kapsam (scope)

Neyin test edileceği ve neyin **edilmeyeceği** açıkça yazılır: hangi ikili dosya/sürüm, hangi bileşenler, hangi ortam (test ortamı mı, üretim mi), hangi veriler (yalnız sentetik). Kapsam dışı bırakılanlar da yazılır (ör. üçüncü taraf sunucular, gerçek kullanıcı verisi).

2. Angajman kuralları (rules of engagement)

- **Yazılı izin** ve yetkili imzası; test penceresi (tarih/saat).
- İzin verilen ve **yasak** yöntemler (ör. hizmet kesintisine yol açacak testler hariç).
- Veri işleme kuralı: gerçek kişisel veri kullanılmaz; bulgular gizli tutulur.
- Durdurma koşulu (kill switch): kritik bir etki görülürse test durur ve derhal bildirilir.
- İletişim ve yükseltme (escalation) noktaları.

3. Yöntem (methodology)

Tanınmış bir metodoloji seçilir ve ona uyulur: mobil için **OWASP MASTG/MASVS**, web için **OWASP WSTG**, genel süreç için **PTES** ya da **NIST SP 800-115**. Yöntem seçimi, sonucun **tekrarlanabilir** ve **karşılaştırılabilir** olmasını sağlar.

4. Test şablonu (sekiz başlık)

Değerlendirmedeki her test aynı şablonla yazılır; bu, projenizin S16 bölümünün de iskeletidir:

Alan	İçerik
Test kimliği	Benzersiz numara
İlgili gereksinim	Hangi gereksinimi/varlığı sınıyor (S17 ile bağ)
Amaç	Ne doğrulanıyor
Ön koşullar	Ortam, sürüm, veriler
Yöntem/adımlar	Tekrarlanabilir biçimde
Beklenen sonuç	Güvenli davranış ne olmalı
Gözlenen sonuç	Ne oldu (kanıtla)
Saldırı potansiyeli / karar	Puanlama + geçti/kaldı + öneri



Takım etkinliği (sınıf içi)

Her takım, kendi projesinden bir varlık seçer (ör. yerel veritabanındaki hassas kayıt) ve onun için **bir** test kartı doldurur: amaç, ön koşul, adımlar, beklenen/gözlenen sonuç, saldırı potansiyeli. Amaç bir açık bulmak değil, **doğru test kartını yazmayı** öğrenmektir.

8. Raporlama

İyi bir güvenlik raporu, bir "kaldınız" listesi değil, **karar verilebilir** bir belgedir:

- **Yönetici özeti:** teknik olmayan okur için genel durum ve en kritik üç bulgu.
- **Yöntem ve kapsam:** ne test edildi, ne edilmedi, hangi metodolojiyle.
- **Bulgular:** her biri kanıt, saldırı potansiyeli ve CVSS, öneri ile.
- **Bulgu–aksiyon tablosu:** geliştiricinin yanıtı ve kapanış durumu.
- **Kalan risk:** kapatılmayan ya da devredilen riskler, gerekçeyle.



Eleştirel okuma alıştırması

Size verilen kısa bir bulgu metnini birlikte okuyun: bu bulgunun saldırı potansiyeli doğru mu derecelendirilmiş? Öneri uygulanabilir mi? "Karşılandı" diyen bir satırın kanıtı var mı? Bu okuma, 13. haftadaki uyum matrisi okumasının provasıdır.

9. Dönem projesi: bu hafta (S16 – test planı ve sonuçları)

1. **Test planı:** En kritik iki–üç varlık/gereksinim için sekiz başlıklı test kartları yazın (S17 ile bağlı).

2. **Yöntem:** Hangi metodolojiyi (MASTG/WSTG/PTES/NIST SP 800-115) temel aldığınızı belirtin.
3. **Sonuçlar:** Testleri çalıştırıp **gözlenen sonuçları** yazın — finalde plan değil, **sonuç** beklenir.
4. **Bulgu–aksiyon:** Vize geri bildirimlerini bir bulgu–aksiyon tablosuna dökün.
5. **Kalan risk:** Kapatmadığınız riskleri ve gerekçesini yazın.

⚠ Etik ve hukuki çerçeve (tekrar)

Sızma testi yalnız **kendi** projeniz ve yetkili olduğunuz sistemler üzerinde yapılır. Başkasının sistemine izinsiz test, amacı ne olursa olsun suçtur. Bütün veriler sentetik olmalı; depoda gerçek sır ya da kişisel veri bulunmamalıdır.

10. Kendini sinama

? 1. Bir ürünün bağımsız değerlendirmesindeki 13 adımı ana hatlarıyla sıralayın. Hazırlık, değerlendirme ve süreklilik aşamaları neleri kapsar? ✓

Hazırlık (1–4): değerlendirme hedefini (TOE) tanımlama, kapsam, güvenlik hedefi/gereksinimler, plan.

Değerlendirme: yöntemleri uygulama (kod inceleme → SAST → DAST → fuzzing → sızma testi), bulguları saldırı potansiyeliyle derecelendirme, raporlama. **Süreklilik:** karar/sertifika, sonra her değişiklikte etki analizi + delta değerlendirme ve sürüm bakımı.

? 2. Değerlendirici hangi iki varsayımla çalışır? Bu neden 'korumanın var olması yetmez' sonucunu doğurur? ✓

(1) Saldırgan sistemi **tam bilir** (Kerckhoffs), (2) saldırgan **yetenekli ve kaynaklıdır**. Bu yüzden bir korumanın sadece bulunması değil; belirli bir **saldırı potansiyeline** dayanması ve bunun **kanıtla** gösterilmesi gerekir.

? 3. Zafiyet değerlendirmesinin yöntemlerini (kod incelemesi, SAST, DAST, fuzzing, sızma testi) neden bu sırada uyguluyoruz? ✓

Ucuz/otomatik/geniş kapsamlı yöntemlerden pahalı/el emeği/derin yöntemlere doğru. Erken ucuz taramalar kolay bulguları eler; pahalı el emeği (fuzzing, sızma testi) yalnız kalan derin sorunlara harcanır → bütçe ve zaman verimli kullanılır.

? 4. ISO/IEC 27001 ile Ortak Kriterler'in test beklentisi nasıl ayrılır? Biri neyi, öteki neyi sertifikalar? ✓

ISO/IEC 27001 **kurumun bilgi güvenliği yönetim sistemini** (süreç/organizasyon) denetler ve sertifikalar. Ortak Kriterler (ISO/IEC 15408) **belirli bir ürünü (TOE)** tanımlı bir güvence düzeyinde teknik olarak değerlendirir ve sertifikalar.

? 5. Saldırı potansiyelinin beş faktörünü sayın. Düşük saldırı potansiyeli neden ciddi bir bulgudur? ✓

Geçen zaman, uzmanlık, ürün hakkında bilgi, fırsat (erişim/pencere), ekipman. Düşük saldırı potansiyeli, az zaman/beceri/araçla sömürülebilir demektir → çok sayıda saldırgan başarabilir → geniş ve olası tehdit, yani yüksek risk.

? 6. Saldırı potansiyeli ile CVSS neyi ölçer? İkisi neden birlikte verilir? ✓

Saldırı potansiyeli saldırıyı gerçekleştirmenin **zorluğunu/maliyetini**; **CVSS** açığın **ciddiyet/etkisini** ölçer. Birlikte verilince hem 'ne kadar kolay' hem 'ne kadar kötü' görülür ve önceliklendirme sağlıklı yapılır.

? 7. Bulgu–öneri–aksiyon döngüsünü açıklayın. Bir bulgu 'güvenlik açığı değil' diye nasıl kapanır? ✓

Her bulguya bir **düzeltilme önerisi** ve sorumlu/**aksiyon** atanır, sonra düzeltme **doğrulandır**. Bir bulgu, bağlam veya telafi kontrolleri nedeniyle gerçekten **sömürülemez** olduğu kanıtlanırsa 'etkilenmez / risk kabul' gerekçesiyle (VEX benzeri) kapatılır.

? 8. Güvenlik etki analizi ile delta değerlendirme arasındaki fark nedir? Hangisi geliştiricinin, hangisi laboratuvarın çıktısıdır? ✓

Etki analizi geliştiricinin çıktısıdır: yapılan değişiklik güvenliği/TOE'yi etkiliyor mu? **Delta değerlendirme laboratuvarın** işidir: etkilenen kısmı bağımsız olarak yeniden değerlendirir (tüm ürünü baştan değil).

? 9. Bir sızma testi planının dört başlığını (kapsam, angajman kuralları, yöntem, test şablonu) ve her birinin amacını yazın. ✓

Kapsam: neyin test edilip edilmeyeceği. **Angajman kuralları:** izinler, sınırlar, zaman, durdurma koşulu. **Yöntem:** metodoloji ve araçlar (WSTG/PTES vb.). **Test şablonu:** tekrarlanabilir test kartları. Amaç: güvenli, etik, tekrarlanabilir ve kapsamı net bir test.

? 10. Angajman kurallarında 'durdurma koşulu' neden bulunur? ✓

Gerçek zarar, veri kaybı veya hizmet kesintisi riskini sınırlamak için. Belirlenen bir eşikte (örn. üretim etkisi ya da kritik bir açık) test **hemen durdurulur** → güvenli ve etik yürütme sağlanır.

? 11. Sekiz başlıklı test kartının alanlarını sayın. Hangi alan S17 uyum matrisine bağlanır? ✓

Örn: **kimlik/no, ilgili gereksinim-hedef, ön koşul, adımlar, beklenen sonuç, gözlenen sonuç, karar (geçti/kaldı), kanıt/ek.** 'İlgili gereksinim / karar' alanı **S17 uyum matrisine** kanıt olarak bağlanır.

? 12. Finalde S16'dan 'plan' değil 'sonuç' beklenmesi ne demektir?



Testin yalnızca nasıl yapılacağını yazılması yetmez; testlerin gerçekten **çalıştırılıp** gözlenen sonuçlarının (geçti/kaldı, kanıt, ekran çıktısı) raporlanması beklenir. Yani plan değil, **gözlenen sonuçlar** teslim edilir.

11. Kaynaklar ve ileri okuma

- **Güvenli programlama teknik kılavuzu** (ders kaynağı) – teslim edilen güvenlik kılavuzunun ve değişiklik/etki analizi belgelerinin yapısı; gereksinim bloğu ve durum ("karşılandı / devredildi / karşılanmadı").
- **OWASP MASVS** ve **MASTG** – mobil uygulama güvenlik gereksinimleri ve test rehberi.
- **OWASP WSTG** – web uygulama güvenlik testi rehberi.
- **PTES** (Penetration Testing Execution Standard) ve **NIST SP 800-115** – sızma testi süreç metodolojileri.
- **Ortak Kriterler (ISO/IEC 15408)** ve ilgili saldırı potansiyeli kılavuzları – 13. haftaya köprü.
- **CVSS** – zafiyet ciddiyet puanlaması.

i Bir sonraki hafta

13. hafta – Güvenlik gereksinimleri. Bu hafta "gereksinim şablonu" ve "uyum matrisi"ni süreç içinde gördük; 13. haftada iyi bir gereksinimin nasıl yazıldığını, izlenebilirlik/uyum matrisini ve Ortak Kriterler, FIPS 140-3, ETSI, EMVCo, PCI, MASVS gereksinim setlerini ayrıntılı işleyeceğiz.